CORS & Same-Origin

On https://app.dev, one different part = cross-origin

scheme	host	port
http://app.dev	https://api.dev	https://app.dev:8443

Simple request + Origin → **Response** Allow-Origin → **JS reads** if the origin matches

Preflight OPTIONS first → **Allow-*** Methods, Headers → **Real request** PUT, JSON, ...

1 Browser asks

```
OPTIONS /items HTTP/1.1
Origin: https://app.dev
```

2 Server allows

```
HTTP/1.1 204 No Content
Access-Control-Allow-Origin: *
```

cookies include + Allow-Credentials: true + named origin

TRAP What happens here?

```
// app.dev calls api.dev, no CORS
fetch("https://api.dev/items", {
  method: "PUT",
});
```

OPTIONS /items

PUT: never sent

The preflight gets no allow headers.

KEY TAKEAWAY

- **origin** scheme + host + port
- **server** Opts in
- **browser** Enforces

? Follow-up questions to expect

- **Does CORS stop the request?** → Simple ones still reach the server. JS can't read them.
- **Why a preflight?** → To ask the server first, before a non-simple request.
- **Is CORS CSRF protection?** → No. A cross-site form POST still arrives.
- **Does curl obey CORS?** → No. Only browsers enforce it.